1. Cos'è il CSIRT Italia (ACN)?

Il CSIRT Italia (Computer Security Incident Response Team) è l'organismo tecnico nazionale per la cybersecurity, istituito presso l'Agenzia per la Cybersicurezza Nazionale (ACN).
È stato trasferito dal Dipartimento Informazioni per la Sicurezza (DIS) all'ACN il 16 settembre 2021, nell'ambito della riforma che ha ridefinito l'architettura nazionale della sicurezza cibernetica.

1.1 Inquadramento Normativo

Il CSIRT Italia è stato istituito con i seguenti riferimenti normativi:
- Decreto Legislativo 18 maggio 2018, n. 65 (attuazione Direttiva NIS - UE 2016/1148)
- Decreto del Presidente del Consiglio dei Ministri 8 agosto 2019, art. 4
- Decreto Legge n. 82 del 14 giugno 2021 (convertito in Legge n. 109 del 4 agosto 2021) - Istituzione dell'ACN.

1.2 Missione

Il CSIRT Italia è responsabile della prevenzione, analisi e gestione degli incidenti informatici che colpiscono reti e infrastrutture critiche nazionali.
Opera come punto di coordinamento nazionale per la risposta agli incidenti cyber e la condivisione di informazioni sulle minacce.

1.3 Ambito di Operatività

Il CSIRT Italia supporta:
- Soggetti essenziali e importanti (definiti dalla normativa NIS e NIS2),
- Pubbliche Amministrazioni centrali e locali,
- Infrastrutture critiche nazionali (energia, trasporti, sanità, finanza, telecomunicazioni),
- Settore privato (su base volontaria o in collaborazione),
- Cittadini e PMI (attraverso campagne di awareness e bollettini di sicurezza).

2. Compiti del CSIRT Italia

I compiti del CSIRT Italia sono articolati in diverse aree di attività, tutte finalizzate a garantire la sicurezza cibernetica nazionale.

2.1 Monitoraggio e Rilevamento

- Monitoraggio continuo degli incidenti informatici a livello nazionale attraverso sistemi di rilevamento avanzati
- Analisi delle reti e dei sistemi informatici per individuare attività sospette e anomalie
- Identificazione proattiva di nuove minacce e vulnerabilità emergenti
- Threat Intelligence: raccolta, analisi e condivisione di informazioni sulle minacce cyber

Dati 2025: Nel primo semestre 2025, il CSIRT Italia ha rilevato 1.549 eventi cyber (+53% rispetto al 2024), di cui 346 classificati come incidenti con impatto confermato (+98%).

2.2 Prevenzione e Preparazione

- Sviluppo e implementazione di misure preventive per proteggere le infrastrutture critiche
- Emissione di preallarmi, allerte e bollettini di sicurezza su vulnerabilità e minacce emergenti
- Divulgazione di informazioni tecniche (CVE, IoC - Indicators of Compromise) alle parti interessate
- Formazione e sensibilizzazione degli operatori attraverso workshop, webinar e materiali didattici
- Comunicazioni preventive di allerta (Alert Preventivi): nel 2025, oltre 5.000 comunicazioni inviate a soggetti italiani

2.3 Gestione degli Incidenti

- Ricezione e gestione delle notifiche di incidenti informatici dai Soggetti NIS (essenziali e importanti)
- Supporto tecnico alle organizzazioni durante la risposta agli incidenti
- Coordinamento della risposta nazionale a incidenti di vasta scala
- Analisi forensica e investigazione tecnica per identificare l'origine e l'impatto degli attacchi
- Supporto al ripristino dei servizi compromessi

Tempistiche di notifica (Decreto NIS2):

- Pre-notifica: entro 24 ore dalla scoperta dell'incidente
- Notifica completa: entro 72 ore (o 24 ore per prestatori di servizi fiduciari)

- Relazione finale: entro un mese dalla notifica

2.4 Cooperazione Nazionale e Internazionale

- Collaborazione con altri CSIRT europei nella rete EU-CyCLONe (European Cyber Crisis Liaison Organisation Network)
- Condivisione di intelligence sulle minacce con partner internazionali
- Coordinamento delle risposte a incidenti transnazionali
- Cooperazione con il settore privato attraverso partnership e protocolli di collaborazione
- Promozione dell'adozione di prassi comuni e standardizzate per il trattamento degli incidenti

2.5 Reportistica e Analisi

- Pubblicazione di report mensili (Operational Summary) sull'andamento della minaccia cyber
- Report semestrali e annuali sugli incidenti informatici in Italia
- Analisi di trend e statistiche sulle minacce cyber
- Documentazione delle lezioni apprese da incidenti significativi

2.6 Figure Chiave: Il Referente CSIRT

Con la Determinazione ACN n. 333017/2025 del 3 ottobre 2025, è stata introdotta la figura del **Referente CSIRT**, operativa da gennaio 2026.

Definizione: Il Referente CSIRT è una persona fisica designata dal Punto di Contatto del soggetto NIS, con il compito di gestire le interlocuzioni operative con il CSIRT Italia e trasmettere le notifiche di incidenti.

Requisiti:

- Competenze tecniche in sicurezza informatica e gestione degli incidenti
- Conoscenza dei sistemi informativi dell'organizzazione
- Autorizzazione formale ad agire in nome e per conto del Soggetto NIS
- Non sono richieste certificazioni specifiche, ma esperienza pratica
- Può essere interno o esterno all'organizzazione
- Possibilità di nominare sostituti con le stesse competenze

Compiti operativi:

- Trasmettere le notifiche di incidenti significativi al CSIRT Italia
- Gestire le comunicazioni tecniche durante la risposta agli incidenti
- Fornire aggiornamenti sullo stato degli incidenti
- Ricevere e implementare le raccomandazioni del CSIRT Italia

- Coordinare le attività di remediation interne

3. Analisi della Campagna Phishing Trenitalia

3.1 Descrizione della Minaccia

Il CSIRT Italia ha rilevato e documentato una campagna di phishing che sfrutta loghi e riferimenti riconducibili a Trenitalia per carpire informazioni personali e finanziarie delle vittime. Questa campagna è stata classificata con il codice **AL03/240322/CSIRT-ITA** ed è stata diffusa nel marzo 2024, con varianti successive nel corso dell'anno.

3.2 Modus Operandi

Fase 1: Distribuzione Email

Le email fraudolente presentano le seguenti caratteristiche:

- Mittente: utilizza domini simili a quelli ufficiali di Trenitalia (typosquatting)
- Oggetto: "Partecipa al sondaggio Trenitalia e ricevi un pass annuale gratuito"
- Grafica: replica fedelmente il logo e i colori aziendali di Trenitalia
- Contenuto: propone la partecipazione a un sondaggio sulla soddisfazione del cliente
- Esca: promessa di ricevere un pass annuale gratuito per i servizi Trenitalia

Fase 2: Sondaggio Fasullo

Cliccando sul link, la vittima viene indirizzata a una pagina web che:

- Presenta domande apparentemente legittime sui servizi Trenitalia
- Simula un'interfaccia professionale con design curato
- Include domande sulla frequenza di utilizzo dei servizi ferroviari
- Richiede valutazioni sulla qualità del servizio e suggerimenti

Fase 3: Furto Dati

Al termine del sondaggio:

- Viene mostrata una schermata che conferma la "vincita" del pass annuale
- Si richiede di cliccare su un link per "riscuotere il premio"
- La vittima viene reindirizzata a un form che richiede:

○ Dati personali (nome, cognome, indirizzo, email, telefono)
○ Dati della carta di credito (numero, CVV, scadenza)
○ Eventualmente, credenziali di accesso a servizi online

- Il pretesto per richiedere i dati della carta è la "verifica dell'identità" o il "pagamento di spese di spedizione simboliche" (es. 1-2 euro)

3.3 Varianti della Campagna

Nel corso del 2024-2025, sono state osservate diverse varianti:

1. Variante "Pagamento non completato": email che avvisano di un presunto pagamento non andato a buon fine per un viaggio di 19,99€, richiedendo di regolarizzare la posizione
2. Variante "Acquisto biglietti": siti clone che simulano la piattaforma ufficiale di acquisto biglietti Trenitalia, con domini fraudolenti
3. Variante "Sondaggio soddisfazione": la variante originale descritta sopra, con promessa di pass annuale

3.4 Indicatori di Compromissione (IoC)

Elementi che permettono di identificare la campagna:

- Domini sospetti: domini che imitano trenitalia.com (es. trenitalia-survey[.]com, trenitalia-premio[.]it, etc.)
- URL anomali: presenza di stringhe sospette nei link (es. bit.ly, shorturl, redirect multipli)
- Certificati SSL: assenza di certificato valido o certificato emesso da CA non riconosciute
- Form di pagamento: richiesta di dati completi della carta (incluso CVV) per operazioni che non li richiederebbero
- Errori linguistici: presenza di errori grammaticali o traduzioni automatiche (alcune versioni utilizzano l'inglese)
-

3.5 Impatto e Statistiche

Il CSIRT Italia ha osservato un significativo aumento delle campagne phishing nel 2024-2025:

Metrica	2024	2025
URL di phishing rilevate	579	927 (+60%)
Eventi cyber totali (sem. 1)	1.011	1.549 (+53%)
Incidenti con impatto confermato	175	346 (+98%)
Alert preventivi inviati	N/A	5.205

Settori più colpiti da phishing in Italia (2024-2025):

- Sanità (campagna contro struttura ospedaliera: 3.000+ email)
- Energia (campagna da casella compromessa: 300+ messaggi)
- Settore finanziario (furto credenziali bancarie)

- Trasporti e logistica (inclusa campagna Trenitalia)
- E-commerce e servizi di spedizione

4. Protezione dell'Organizzazione dalla Campagna Phishing

Per proteggere efficacemente un'organizzazione dalla campagna phishing Trenitalia e da minacce simili, è necessario implementare un approccio di difesa multilivello che combini misure tecniche, organizzative e di formazione.

4.1 Misure Tecniche

4.1.1 Filtri Email e Anti-Spam

- Implementare soluzioni avanzate di email security (es. Proofpoint, Mimecast, Microsoft Defender for Office 365)
- Configurare filtri anti-phishing con machine learning per rilevare email sospette
- Bloccare domini noti per campagne phishing (utilizzare IoC del CSIRT Italia)
- Implementare SPF, DKIM e DMARC per autenticare le email in ingresso
- Abilitare banner di avviso per email provenienti da mittenti esterni

4.1.2 Web Filtering e DNS Security

- Implementare DNS filtering per bloccare l'accesso a domini malevoli (es. Cisco Umbrella, Cloudflare Gateway)
- Utilizzare web proxy con ispezione SSL/TLS del traffico HTTPS
- Bloccare siti di phishing noti attraverso feed di threat intelligence
- Implementare controlli su URL shortener (bit.ly, tinyurl) che vengono spesso usati per mascherare link malevoli

4.1.3 Endpoint Protection

- Installare soluzioni EDR/XDR (Endpoint Detection and Response) su tutti i dispositivi
- Configurare browser con estensioni anti-phishing (es. Netcraft, PhishTank)
- Abilitare protezione SmartScreen/Safe Browsing nei browser aziendali
- Limitare i privilegi degli utenti (principle of least privilege) per ridurre l'impatto di compromissioni

4.1.4 Autenticazione Multi-Fattore (MFA)

- Implementare MFA su TUTTI gli account aziendali, in particolare:

○ Email aziendale
○ VPN e accessi remoti
○ Sistemi amministrativi
○ Servizi cloud (Microsoft 365, Google Workspace, AWS, etc.)

- Preferire MFA resistente al phishing (FIDO2, passkey) rispetto a SMS o TOTP

- Implementare Conditional Access per richiedere MFA in base al rischio (es. accesso da IP sconosciuto)

4.2 Misure Organizzative

4.2.1 Politiche e Procedure

- Sviluppare e documentare policy anti-phishing chiare e accessibili
- Definire procedure di reporting per email sospette (es. pulsante "Report Phishing" in Outlook)
- Stabilire protocolli di risposta agli incidenti phishing
- Implementare processo di verifica per richieste di dati sensibili o pagamenti
- Richiedere verifica telefonica (out-of-band) per richieste insolite via email

4.2.2 Gestione delle Credenziali

- Implementare password manager aziendale (es. 1Password Business, Bitwarden)
- Richiedere password complesse e uniche per ogni servizio
- Implementare rotazione periodica delle password per account privilegiati
- Monitorare credenziali compromesse (es. Have I Been Pwned Enterprise)
- Forzare reset password immediato se si sospetta compromissione

4.2.3 Monitoraggio e Detection

- Implementare SIEM (Security Information and Event Management) per correlazione eventi
- Monitorare log di accesso per comportamenti anomali:

○ Tentativi di login falliti multipli
○ Accessi da località geografiche inusuali
○ Accessi in orari non lavorativi
○ Modifiche a regole di forwarding email

- Configurare alert automatici per eventi critici
- Condurre threat hunting proattivo per identificare compromissioni non rilevate

4.3 Formazione e Awareness

4.3.1 Programma di Security Awareness

- Formazione obbligatoria anti-phishing per tutti i dipendenti (almeno annuale)
- Training specifico per utenti ad alto rischio (CEO, CFO, HR, Finance)
- Moduli formativi su:

○ Come riconoscere email di phishing
○ Verifica della legittimità dei mittenti
○ Analisi di URL e link prima di cliccare
○ Riconoscimento di urgency tactics e social engineering

○ Procedure di reporting

- Utilizzare piattaforme di awareness training (es. KnowBe4, Proofpoint Security Awareness)

4.3.2 Simulazioni di Phishing

- Condurre simulazioni regolari (almeno trimestrali) per testare la preparazione degli utenti
- Variare le tipologie di phishing simulato (credential harvesting, malware, BEC)
- Fornire formazione mirata agli utenti che cadono nelle simulazioni
- Tracciare metriche di miglioramento nel tempo (phish-prone percentage)
- Celebrare i successi: riconoscere pubblicamente chi segnala correttamente email sospette

4.3.3 Comunicazioni e Promemoria

- Inviare newsletter mensili di security awareness
- Condividere alert del CSIRT Italia su campagne phishing in corso
- Pubblicare case study di incidenti reali (anonimizzati)
- Creare poster e materiale visivo per uffici ("How to spot a phishing email")
- Organizzare Cybersecurity Awareness Month annuale con eventi dedicati

4.4 Risposta agli Incidenti

4.4.1 Incident Response Plan

Sviluppare e documentare un piano di risposta specifico per incidenti phishing:

4. Detection e Reporting: l'utente segnala email sospetta al team IT/Security
5. Triage: il team analizza l'email per determinare se è phishing reale
6. Containment:

○ Bloccare mittente e dominio su email gateway
○ Rimuovere email da tutte le mailbox
○ Bloccare URL malevoli su web filter/DNS

7. Investigation:

○ Identificare tutti i destinatari
○ Determinare chi ha cliccato sul link o inserito credenziali
○ Analizzare log per tentativi di accesso con credenziali compromesse

8. Remediation:

○ Reset password per utenti compromessi
○ Revoca sessioni attive
○ Blocco carte di credito se forniti dati finanziari
○ Notifica alle banche se necessario

9. Recovery: ripristinare operatività normale con misure di sicurezza rafforzate
10. Lessons Learned: condurre post-incident review per identificare miglioramenti

4.4.2 Notifica al CSIRT Italia

Per i Soggetti NIS (essenziali e importanti), in caso di incidente significativo:

- Il Referente CSIRT deve trasmettere pre-notifica entro 24 ore
- Notifica completa entro 72 ore con dettagli tecnici
- Relazione finale entro 1 mese
- Su base volontaria: condividere IoC e dettagli tecnici per aiutare altri soggetti

4.5 Indicatori di Una Email di Phishing

Educare gli utenti a riconoscere questi red flag:

Indicatore	Cosa Verificare
Mittente	Indirizzo email sospetto o dominio simile ma non identico (trenitalia-italia.com invece di trenitalia.com)
Urgenza	Richieste di azione immediata, minacce, scadenze pressanti
Saluto generico	"Gentile cliente" invece del nome specifico
Errori	Errori grammaticali, ortografici o di formattazione
Link sospetti	Hover sul link per vedere URL reale. Verificare dominio. URL shortener (bit.ly) sospetti.
Allegati	Allegati non richiesti, estensioni sospette (.exe, .zip, .js)
Richieste anomale	Richiesta di password, dati carta di credito completi (con CVV), conferme inusuali
Offerte irrealistiche	Premi, vincite, sconti troppo vantaggiosi (pass annuale gratuito)

5. Conclusioni

Il CSIRT Italia rappresenta un pilastro fondamentale della cybersecurity nazionale, operando come punto di coordinamento per la prevenzione, rilevamento e risposta agli incidenti informatici che minacciano le infrastrutture critiche e le organizzazioni italiane.

5.1 Il Ruolo Strategico del CSIRT

Le attività del CSIRT Italia sono essenziali per:

- Garantire la sicurezza nazionale nello spazio cibernetico attraverso monitoraggio continuo e analisi delle minacce
- Coordinare la risposta nazionale a incidenti di vasta scala, minimizzando l'impatto su economia e società
- Facilitare la condivisione di informazioni sulle minacce tra settore pubblico e privato
- Promuovere una cultura della cybersecurity attraverso awareness, formazione e best practices
- Supportare l'implementazione della normativa NIS2 e il rafforzamento della resilienza cyber delle organizzazioni italiane

5.2 La Minaccia del Phishing

L'analisi della campagna phishing Trenitalia evidenzia come questa tipologia di attacco rimanga una delle minacce più pervasive e in continua evoluzione. I dati del 2024-2025 mostrano un incremento significativo (+60%) delle URL di phishing rilevate, con campagne sempre più sofisticate e mirate.

Elementi chiave emersi dall'analisi:

- Il fattore umano rimane il punto debole principale - gli attaccanti sfruttano tecniche di social engineering sempre più elaborate
- Le campagne utilizzano brand riconosciuti (Trenitalia, banche, corrieri) per aumentare la credibilità
- La qualità grafica e linguistica dei tentativi di phishing è migliorata significativamente, rendendo più difficile il riconoscimento
- Gli attaccanti utilizzano tecniche multi-fase per aumentare il tasso di successo

5.3 Strategie di Protezione

La protezione efficace contro il phishing richiede un approccio olistico che combini tecnologia, processi e persone. Come evidenziato dal Rapporto Clusit 2025, almeno il 10% degli attacchi potrebbero essere evitati con una migliore formazione del personale.

Priorità di implementazione:

11. Formazione continua: programmi di security awareness con simulazioni regolari
12. MFA universale: implementazione su tutti gli account, con preferenza per soluzioni phishing-resistant
13. Difese tecniche stratificate: email filtering, DNS security, EDR, web filtering
14. Procedure di verifica: processi chiari per validare richieste sensibili
15. Incident response preparato: piano testato e team addestrato

5.4 Collaborazione con il CSIRT Italia

Le organizzazioni devono:

- Monitorare regolarmente gli alert e bollettini pubblicati dal CSIRT Italia
- Implementare tempestivamente le contromisure raccomandate
- Per Soggetti NIS: designare il Referente CSIRT e assicurare conformità agli obblighi di notifica
- Condividere informazioni su incidenti e IoC per contribuire alla difesa collettiva
- Partecipare a iniziative di collaborazione pubblico-privato

5.5 Prospettive Future

Il panorama della cybersecurity continuerà ad evolversi con sfide crescenti:

- Intelligenza Artificiale: gli attaccanti utilizzeranno sempre più AI per campagne phishing altamente personalizzate e convincenti
- Deepfake: video e audio falsificati renderanno più difficile la verifica dell'identità
- Supply Chain: attacchi sempre più sofisticati attraverso fornitori e partner
- Geopolitica: crescita di attacchi motivati da conflitti internazionali

In questo contesto, il ruolo del CSIRT Italia diventa sempre più cruciale, non solo come centro operativo di risposta agli incidenti, ma come catalizzatore di una cultura della cybersecurity diffusa e matura in tutto il tessuto economico e sociale italiano.

Riferimenti e Contatti

CSIRT Italia: https://www.csirt.gov.it
ACN - Agenzia per la Cybersicurezza Nazionale: https://www.acn.gov.it
Email PEC CSIRT: csirt@pec.acn.gov.it
Portale NIS: https://portale.acn.gov.it
Documenti di riferimento:

- RFC 2350 - CSIRT Italia Profile
- D.Lgs. 138/2024 - Attuazione Direttiva NIS2

- Determinazione ACN n. 333017/2025 - Referente CSIRT
- Rapporto Clusit 2025 - Cybersecurity in Italia